

Blatt 7

Web-Security und Intrusion Prevention

Luis Staudt

Aufgabe 1: Setup

Keycloak wird über die bereitgestellte `docker-compose.yml` gestartet (`docker compose up`). Die Compose-Datei mappt `"8081:8080"`, sodass die Admin-Konsole unter `http://localhost:8081` erreichbar ist (containerintern Port 8080). Die Zugangsdaten werden über die Umgebungsvariablen `KEYCLOAK_ADMIN=admin` und `KEYCLOAK_ADMIN_PASSWORD=admin` gesetzt; der Login erfolgt folglich mit `admin / admin` und damit über ein Default-Passwort.

Die Admin-Konsole öffnet sich nach dem Login im Realm *master*.

Aufgabe 2: User anlegen

Im *master*-Realm wird nur Keycloak selbst verwaltet. Für die Anwendung wird daher ein eigener Realm *hfuBereich* angelegt und darin werden zwei Benutzer erstellt:

- userCM: Claudia Müller, cm@hfuBereich.de
- userHM: Hans Meier, hm@hfuBereich.de

Figure 1 zeigt die Benutzerliste des Realms *hfuBereich* in der Admin-Konsole mit beiden Benutzern.

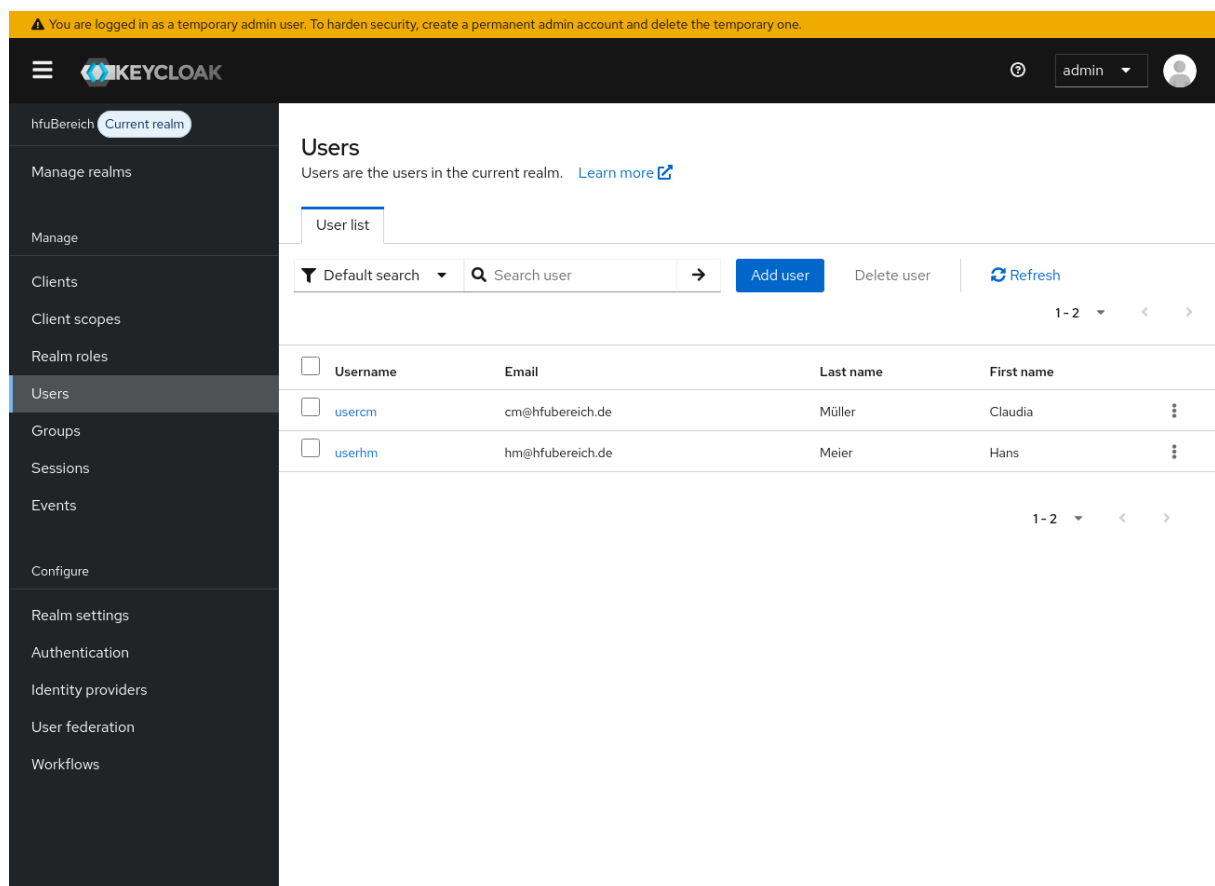


Abbildung 1: Admin-Konsole, Realm *hfuBereich*, mit den Benutzern *userCM* und *userHM*.

Für den Login-Test können sich die Benutzer über die Account-Konsole anmelden, URL-Form `http://<Adresse>/realms/hfuBereich/account`. Damit der Login sofort gelingt, muss den Benutzern ein nicht temporäres Passwort gesetzt werden, da Keycloak andernfalls beim ersten Login einen Passwortwechsel erzwingt. Nach dem Setzen eines Passworts (hier `test1234`) und `emailVerified=true` gelingt die Anmeldung ohne weitere Schritte.

Aufgabe 3: MFA mit OTP konfigurieren

Für userHM wird ein zweiter Faktor erzwungen, indem die Required Action `CONFIGURE_TOTP` gesetzt wird; alternativ lässt sich dies realmweit über *Authentication* → *Required Actions* konfigurieren.

Beim nächsten Login verlangt Keycloak die Einrichtung eines TOTP-Authenticators (*Mobile Authenticator Setup*) und zeigt einen QR-Code, der mit Google Authenticator, FreeOTP oder vergleichbaren Anwendungen gescannt wird (Figure 2). Anschliessend ist bei jeder Anmeldung zusätzlich zum Passwort der sechsstellige Einmal-Code einzugeben; der zweite Faktor ist damit aktiv.

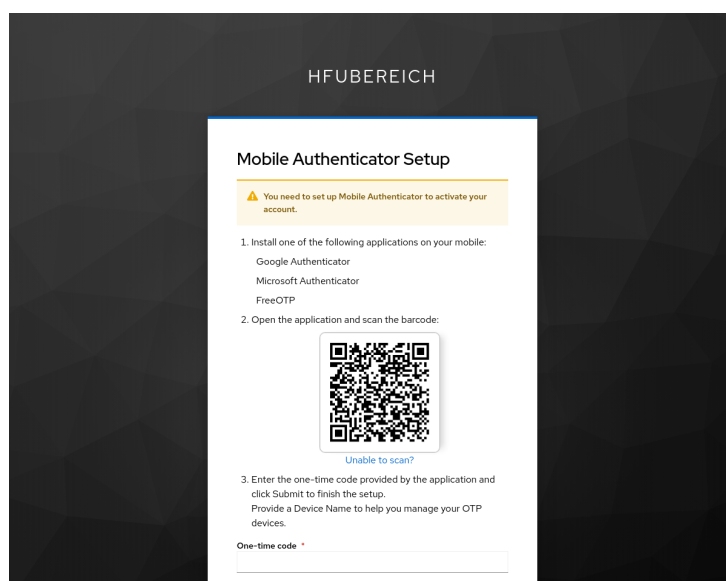


Abbildung 2: Erzwungene OTP-Einrichtung für userHM beim Login (QR-Code + Einmal-Code).

Aufgabe 4: Service Provider (Nextcloud) per SAML anbinden

Nextcloud soll als SAML-SP über Keycloak (IdP) angemeldet werden. Der Ablauf gliedert sich in vier Schritte.

1) IdP-Metadaten in Keycloak. Unter *Realm Settings* liefert Keycloak die SAML-Metadaten des Realms. Die relevanten Werte sind:

```
1 entityID (IdP) : http://<keycloak>/realms/hfuBereich
2 SSO-Endpoint   : http://<keycloak>/realms/hfuBereich/protocol/saml
3 Metadaten-URL  : http://<keycloak>/realms/hfuBereich/protocol/saml/descriptor
```

2) SAML-Client in Keycloak. Für Nextcloud wird ein Client vom Typ *saml* angelegt. Wichtige Einstellungen sind:

- Client-ID = die SP-EntityID (Nextcloud-Metadaten-URL), etwa `http://<nextcloud>/apps/user_saml`
- Valid Redirect URI / ACS: `http://<nextcloud>/apps/user_saml/saml/acs`
- *Sign Assertions* aktiv, Name-ID-Format `username`
- Attribut-Mapper für `username`, `email`, `firstName` und `lastName`, damit Nextcloud die Felder zuordnen kann.

3) Nextcloud einrichten. Die Nextcloud-Oberfläche wird geöffnet und ein initialer Admin angelegt; die empfohlenen Apps, vor allem Nextcloud Office, werden nicht installiert, da sie das Log fluten. Anschliessend wird die App *SSO & SAML authentication* installiert und konfiguriert:

- Attribut zur Identifikation des Nutzers: `username`
- IdP Entity ID, SSO-URL und das X.509-Signaturzertifikat des IdP aus den Keycloak-Metadaten eintragen.
- Service-Provider-Daten (EntityID/ACS) passend zum Keycloak-Client.

4) Funktionstest. Beim Aufruf von `/apps/user_saml/saml/login` wird der Browser zum Keycloak-Login (Realm hfubereich) weitergeleitet. Nach der Anmeldung als userCM leitet Keycloak mit einer signierten SAML-Assertion (HTTP-POST-Binding) an den ACS-Endpunkt von Nextcloud zurück, das daraufhin eine lokale Sitzung öffnet. Figure 3 zeigt das Ergebnis: userCM ist ohne separates Nextcloud-Passwort angemeldet, die Attribute wurden korrekt übernommen (Full name usercm, E-Mail cm@hfubereich.de).

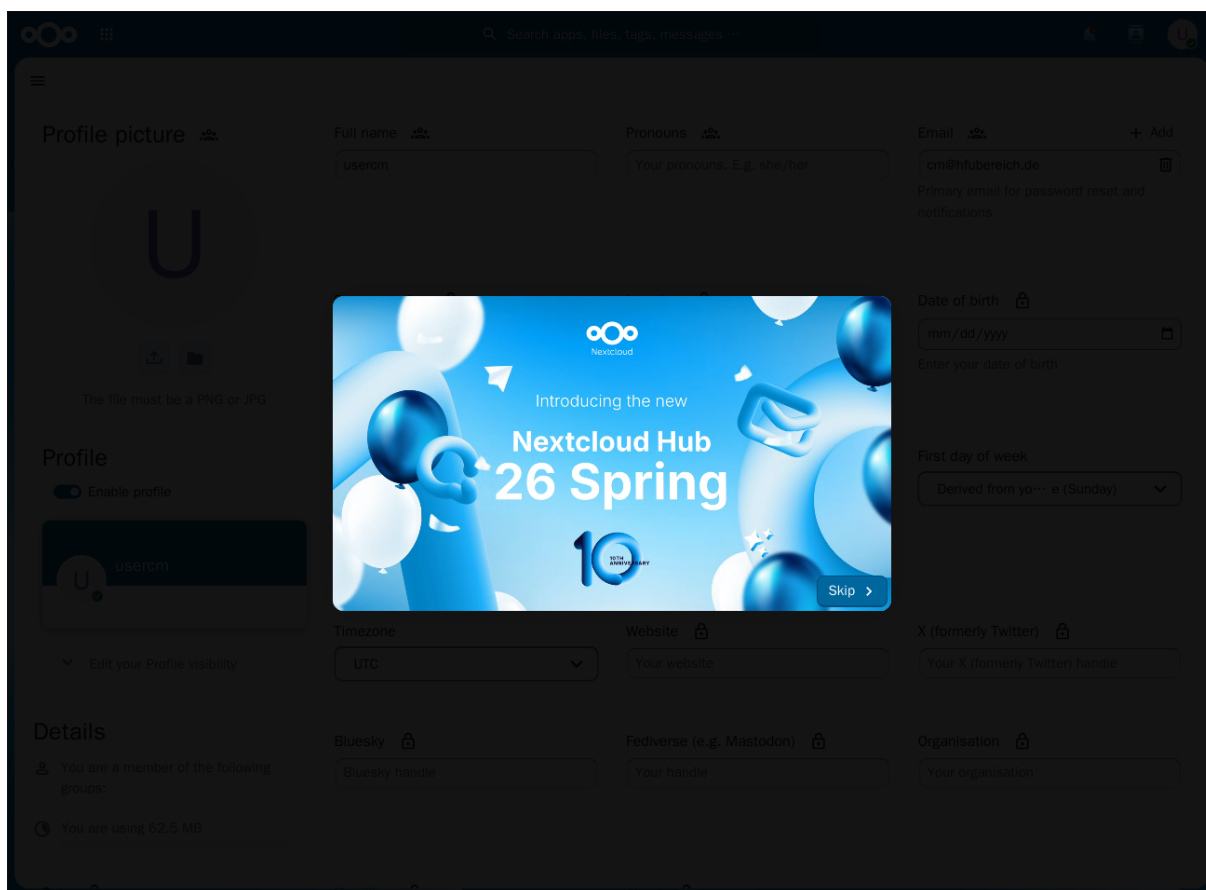


Abbildung 3: Nextcloud nach SAML-SSO über Keycloak: userCM ist angemeldet, Attribute gemappt.

Bei der Umsetzung waren zwei Punkte entscheidend:

- **HTTPS ist Pflicht.** Die App `user_saml` setzt ihr Zustands-Cookie `saml_data` mit `SameSite=None`. Moderne Browser akzeptieren solche Cookies nur mit `Secure-Flag`, also über HTTPS. Über reines HTTP ging das Cookie beim ACS verloren („Cookie was not present“), wodurch eine Redirect-Schleife entstand. Als Lösung wurde Nextcloud hinter einen TLS-Reverse-Proxy (NginX, selbstsigniertes Zertifikat) auf Port 8443 gestellt und `overwritehost` sowie `overwriteprotocol` auf `https` gesetzt.

- **Keine doppelten Attribute.** Der Default-Scope `role_list` erzeugt pro Rolle ein eigenes `<Attribute Name="Role">`. Nextcloud lehnt die Assertion dann mit „duplicated Name“ ab. Der Scope wurde daher vom Client entfernt.

Das vollständige Setup (Keycloak-Konfiguration per Admin-REST-API, Nextcloud per `occ`) liegt reproduzierbar als `setup-saml.sh` bei.

Vergleich: SAML-SSO

Der IdP (Keycloak) übernimmt die Authentifizierung zentral; der SP (Nextcloud) vertraut der signierten Assertion und führt selbst keine Passwortprüfung durch. Wird ein zweiter Dienst an denselben IdP angebunden, entsteht Single-Sign-On: Eine bestehende IdP-Sitzung wird wiederverwendet, sodass eine erneute Anmeldung entfällt.